

Lösungsheft

Tag 12

Musterlösungen zu den elf Aufgaben
des Aufgabenhefts – RPA-Governance,
Audit Trail und Security by Design.

Musterlösungen · nicht die einzige Antwort

Hinweis:

Musterlösungen sind Diskussionsbasis,
nicht die einzige korrekte Lösung.

Begleitend:

Aufgabenheft & Lehrskript Tag 12

Dozent:

Can Siebert

Niveau-Mix:

3 L1 · 5 L2 · 3 L3

Hinweise zu den Musterlösungen

Die folgenden Musterlösungen sind *eine* mögliche, didaktisch nachvollziehbare Lösung – sie sind nicht die einzig richtige. Insbesondere auf L2 und L3 sind mehrere Begründungswege legitim, solange sie:

- den im Lehrskript eingeführten Begriffsapparat (Lifecycle, RACI, Exception-Typen, Security by Design) sauber nutzen,
- Annahmen explizit machen, statt sie zu verschleiern,
- Zielkonflikte (Speed vs. Compliance, Standardisierung vs. Akzeptanz) benennen, statt sie wegzudefinieren,
- zu einer klar formulierten Entscheidung führen – mit Frühwarnsignalen.

Nutzung im Coaching

Vergleichen Sie Ihre eigene Antwort *vor* der Musterlösung. Wo weicht Ihre Argumentation ab? Ist die Abweichung eine andere Annahme – oder ein Denkfehler? Genau dort entsteht der Lerneffekt.

Niveau L1 – Wissen & Reproduktion

Hilfsvideos zu diesem Tag

Die folgenden YouTube-Erklärvideos vermitteln die Inhalte, die Sie zur Bearbeitung der Aufgaben benötigen. Klicken Sie auf den Titel, um das Video direkt zu öffnen; die vollständige URL steht in Klammern.

1. Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

<https://youtu.be/jOpgFmyz70Y>

(URL: <https://youtu.be/jOpgFmyz70Y>)

2. Change Management mit ADKAR — Veränderung als Lernreise

<https://studyflix.de/jobs/karriere-tipps/change-management-7826/video>

(URL: <https://studyflix.de/jobs/karriere-tipps/change-management-7826/video>)

3. Widerstand gegen Veränderung produktiv machen

<https://youtu.be/9zTC87rzeI8>

(URL: <https://youtu.be/9zTC87rzeI8>)

Tipp: Öffnen Sie das Video, lassen Sie es im Hintergrund laufen und arbeiten Sie parallel an der Aufgabe.

Aufgabe 1 – Bot-Lifecycle & Governance-Rollen

L1 • Wissen

~ 8 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

Zuordnung Phase → primäre Rolle:

Phase	Primäre Rolle	Was passiert konkret
Idea	Process Owner / Change Owner	Bedarf identifizieren, Business-Case-Skizze.
Assessment	Bot Owner + Process Owner	Eignung prüfen (Volumen, Regelbasiertheit, Stabilität, Risiko); Go/No-Go-Vorschlag.
Design	Developer + Reviewer	Soll-Flow, Exception-Logik, Datenzugriffe entwerfen.
Build	Developer	Implementierung gegen Standards (Naming, Logging).
Test	Reviewer/QA	Funktional + nicht-funktional (Last, Recovery); Pass/Fail-Protokoll.
Deploy	Operations + Security Owner	Freigabe, Account-Setup, Vault, Monitoring scharf schalten.
Run	Operations	Health, Queue, Erfolgsquote, Exceptions; MTTR steuern.
Improve	Bot Owner + Developer	Lessons Learned, Optimierung, Versions-Update.
Retire	Process Owner + Security	Zugriffe entziehen, Archivierung Audit-Trail, Doku abschließen.

Assessment: Entscheidung *Bot ja/nein* – produziert ein Fit-Profil (Volumen, Stabilität, Risiko) und einen Erstentwurf des Business Case.

Test: Funktionale und nicht-funktionale Prüfung (Last, Recovery, Exception-Pfade); Pass/Fail-Protokoll als Voraussetzung für UAT/Deploy.

Retire: Zugriffe entziehen, Audit Trail archivieren, Prozess-Doku abschließen – *nicht* der “Bot löschen”-Klick, sondern ein eigener Schritt mit Owner.

Risiken bei ausgelassener Improve-Phase:

- *Drift:* UI-Änderungen werden nicht nachgeführt, Exception Rate steigt unbemerkt; der Bot verursacht im Stillen mehr Aufwand als er spart.
- *Wissensverlust:* Erkenntnisse aus Incidents fließen nicht in Standards zurück; andere Bots wiederholen denselben Fehler.

Aufgabe 2 – Vier nicht verhandelbare Governance-Standards

L1 • Wissen

~ 8 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

Vier Standards – konkret und mit Konsequenz:

1. **Naming & Versionierung.** Format: <Domain>_<Prozess>_<Action>_v<Major>.<Minor>, z.B. Finance_Invoice_Posting_v2.3. Versionssprünge nach SemVer: Major bei API-Bruch, Minor bei Erweiterung, Patch bei Bugfix. *Konsequenz bei Verletzung:* Bot wird im Repository abgelehnt; ohne Versionsnummer kein Audit-Trail-Eintrag möglich.
2. **Logging-Minimum.** Pro Bot-Run geloggt: BotID, Version, InputRef, Action, TargetSystem, ResultStatus, ExceptionCode, ProcessedBy, Timestamp. Sensible Felder maskiert oder ghasht. *Konsequenz bei Verletzung:* Bot bleibt in Dev oder Test – keine Prod-Freigabe.
3. **Exception Codes.** Zentral gepflegtes Code-Verzeichnis pro Domäne (ERR_INV_001 = *MissingCostCenter*, ERR_INV_002 = *DuplicateInvoice* ...). Codes referenzieren Playbooks. *Konsequenz:* Ohne Exception-Code-Mapping wird ein neuer Bot nicht ausgerollt.
4. **Freigabe vor Produktion.** Vier-Augen-Prinzip: Reviewer (Code/Standards) und Process Owner (fachliche Korrektheit), bei High-Risk-Bots zusätzlich Security Owner. Schriftliche Freigabe im Ticket. *Konsequenz:* Bots ohne Freigabe-Ticket werden aus Prod entfernt – hartes Stop-Kriterium.

Fünfter Standard (Vorschlag): *Rollback-Plan vor Go-Live* – jeder Bot benötigt einen dokumentierten Stop- und Rollback-Pfad (alte Version, manuelle Notfall-Variante, Verantwortlicher) bevor er live geht. Begründung: Sobald ein Bot läuft, geht jede Sekunde Stillstand auf Kosten des Fachbereichs – Rollback muss *vorher* klar sein, nicht im Incident verhandelt werden.

Aufgabe 3 – Exception-Typen & Audit-Trail-Felder

L1 • Wissen

~ 10 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Exception-Typen mit drei Beispielen je Domäne:

Typ	Rechnungsverarbeitung	HR-Onboarding	Bestellabwicklung
Business	ApprovalRequired (> 10 k €), DuplicateInvoice, ApprovalDeadlineMissed	ContractNotSigned, ManagerApprovalMissing, RoleNotDefined	CreditLimitExceeded, BlockedCustomer, MissingApproval
System	ERPDown, Timeout, OCR-Service down	AD-NotReachable, MailServerDown, HR-System Timeout	SAP-Down, WMS-Timeout, EDI-Channel down
Data	MissingCostCenter, UnknownVendor, WrongCurrency	MissingTaxID, InvalidIBAN, MissingDepartment	MissingArticleNumber, InvalidPriceList, MissingShippingAddress

2. Audit-Log-Template (Mindestumfang):

- LogID (UUID, append-only)
- BotID + Version (z. B. Finance_Invoice_Posting_v2.3)
- Timestamp (ISO 8601, UTC, append-only)
- InputRef (z. B. Rechnungsnummer + Ticket-ID)
- Action (z. B. POST_INVOICE, UPDATE_VENDOR)
- TargetSystem + TargetObject
- ResultStatus (Success / BusinessException / SystemException / DataException) – append-only
- ExceptionCode (Referenz zum Playbook)
- ProcessedBy (Bot-Account; bei Handover: Name des Operators)
- Reason (Freitext, optional)

3. Append-only-Felder: LogID, Timestamp, ResultStatus. Begründung: Ohne diese drei kann nachträgliche Manipulation Schaden vertuschen – Auditor verlangt *Integrität*, nicht nur *Vollständigkeit*. Änderungen werden über neue Log-Einträge dargestellt (Event-Sourcing-Prinzip).

Niveau L2 – Anwendung & Transfer

Aufgabe 4 – Governance-Minimum in 45 Minuten

L2 • Anwendung

~ 30 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. RACI (Auszug, sechs Rollen über fünf Tätigkeiten):

Tätigkeit	PO	Bot-Own.	Dev	QA	Sec	Ops
Bot-Idee bewerten	R/A	C	I	I	C	I
Code reviewen	I	C	R	A	C	I
Freigabe vor Prod	C	R	I	C	A	C
Run & Monitoring	I	A	I	I	I	R
Incident bearbeiten	C	A	C	I	C	R

2. Vier nicht verhandelbare Standards:

- *Versionierung* (SemVer, Major-Minor-Patch im Bot-Namen).
- *Logging-Minimum* (Felder wie in Aufgabe 3; sensible Daten maskiert).
- *Exception Codes* (zentrales Verzeichnis, Mapping zu Playbooks).
- *Freigabe vor Prod* (Vier-Augen, schriftlich im Ticket).

3. Release Flow mit zwei Gates:

Build → *Test* → **Gate 1** (QA + Standards-Check) → *UAT* → **Gate 2** (Process Owner + Security Owner) → *Deploy* → *Monitoring*.

Gate 1 entscheidet über technische Reife (Code-Standards, Tests, Logging). *Gate 2* entscheidet über fachliche und Risiko-Freigabe – ist nicht delegierbar.

4. Fast-Track-Regel: Kleine Bots dürfen Gate 2 ohne Security Owner passieren, wenn *alle* folgenden Bedingungen erfüllt sind:

- kein Schreibzugriff auf Finance- oder HR-Systeme,
- kein Umgang mit PII oder Gesundheitsdaten,
- maximal 100 Transaktionen pro Tag,
- Read-only-Operation auf nicht-kritischen Systemen,
- dokumentierter Rollback-Pfad im Repository.

Guardrail: Verletzt ein Fast-Track-Bot eine der vier Standards (Logging, Versionierung, Exception Codes, Freigabe), wird er sofort *ohne Diskussion* aus Prod gezogen – keine Ausnahmen.

Andere RACI-Ausprägungen sind legitim, solange Accountability eindeutig bleibt und Standards plus Gates klar sind.

Aufgabe 5 – Audit Trail Standard & fünf Exception-Playbooks

L2 • Anwendung

~ 25 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Audit-Log-Template (kompakt):

Feld	Typ	Pflicht?	Anmerkung
LogID	UUID	ja	append-only
Timestamp	ISO 8601	ja	append-only
BotID	String	ja	inkl. Version
Version	SemVer	ja	
InputRef	String	ja	z. B. Rechnungsnummer
Action	Enum	ja	POST/UPDATE/READ
TargetSystem	String	ja	ERP, CRM, Portal
ResultStatus	Enum	ja	append-only
ExceptionCode	String	nein	nur bei Exception
ProcessedBy	String	ja	Bot-Account / Operator
Reason	Text	nein	Begründung

Aufbewahrung: Finance-Logs 5 Jahre (steuerlich begründet, GoBD); Logs zentral, role-based Access (Bot Owner + Audit + Security), Export-API für Auditor.

2. Playbooks (kompakt):

Exception	Owner	Reaktion	SLA	Eskalation
MissingCostCenter	Buchhaltung	Queue für Klassifikation; Mail an Anforderer	24 h	Teamleitung nach 48 h
DuplicateInvoice	Buchhaltung	Stopp Bot; Ticket; Vorgang an Bearbeitenden	8 h	Process Owner nach 24 h
ERPNotReachable	IT-Operations	Retry 3x exponentiell; Ticket an IT; Queue parken	2 h	Plattformbetrieb nach 2 h
ApprovalThreshold	Bot Owner	Vier-Augen-Freigabe-Task an Genehmiger	24 h	PO + nächste Hierarchie nach 48 h
PortalUIChanged	Bot Owner + Dev	Bot pausieren; Selektor-Update; Regression-Test	24 h	Bereichsleitung nach 72 h

3. Zwei KPIs mit Anti-Gaming:

- **Exception Rate** $\leq 12\%$. **Anti-Gaming:** Zählung erfolgt *automatisch* aus dem Audit-Log; manuelles “Umlabeln” einer Exception auf *Success* löst zusätzliche Eintragspflicht im Log aus (Reviewer + Begründung).
- **MTTR** $< 4\text{ h}$ (von Exception bis Lösung/Handover). **Anti-Gaming:** Stoppt nicht beim “Ticket-

erstellt“, sondern beim *Resolved-with-Outcome*; Ticket-Schließung ohne Resolution-Code wird abgewiesen.

Aufgabe 6 – Security-by-Design Guardrails entwerfen

L2 • Anwendung

~ 25 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Account-Konzept:

- *Bot-Accounts* sind technische Service-Accounts (*srv_rpa_invoice_prod*, *srv_rpa_invoice_dev*). Nie identisch mit Personal-Accounts; nie “geteilt”.
- Passwörter und API-Keys liegen im *Credential Vault* (z. B. konzeptionell HashiCorp Vault, CyberArk, Azure Key Vault). Bot fordert Secret zur Laufzeit an – *nie* im Code, nie in Konfigurationsdateien.
- Rotation: mindestens quartalsweise; bei Vorfall sofort.

2. Least Privilege (drei Beispiel-Bots):

Bot	Minimal-Berechtigungen
InvoiceBot	ERP: <i>Read</i> Kreditoren, <i>Write</i> Buchungsbelege (nur ein Belegtyp); <i>kein</i> Zugriff auf HR, kein Stammdaten-Ändern.
HR-OnboardingBot	AD: nur <i>User-Create</i> in zwei OUs; Mail: <i>Send-as</i> auf eine Funktions-Mailbox; <i>kein</i> Read auf andere Mitarbeiterdaten.
ReportingBot	DWH: <i>Read-only</i> auf zwei Views; Mail-Versand an feste Empfängerliste; <i>kein</i> Schreibzugriff irgendwo.

3. Drei SoD-Regeln (Finance-Bot):

- *Anlegen* eines Kreditors und *Freigeben* desselben Kreditors dürfen nicht durch denselben Account erfolgen.
- *Erfassen* und *Freigeben* einer Zahlung sind getrennt; Bot darf maximal eine der beiden Operationen.
- *Änderung* von Stammdaten (Bankverbindung, Adresse) und *Auslösen* einer Zahlung dürfen nicht in derselben Bot-Session erfolgen (Cooling-off-Periode oder Vier-Augen).

4. PII-/Datenschutz-Logik:

- *Nie im Klartext geloggt*: Gehalt, Gesundheitsdaten, vollständige IBAN, Geburtsdatum, Personalnummer.
- *Lösungen*: Hashing (z. B. Personalnummer als SHA-256), Maskierung (DE89****6789), oder ganz weglassen und Verweis auf ID nutzen.
- Zugriff auf PII-haltige Logs nur für Bot Owner + Audit + Datenschutzbeauftragter; Vier-Augen-Zugriff dokumentiert.

5. Drei nicht verhandelbare Guardrails vor Go-Live:

- Bot-Account ist nicht identisch mit einem Personal-Account, Secrets im Vault.
- SoD-Prüfung dokumentiert; kein Bot mit *Anlegen* + *Freigeben* im selben Account.
- Logging-Integrität (append-only) und PII-Maskierung geprüft – Security Sign-off im Ticket.

Aufgabe 7 – Change-Paket für Mitarbeitende “hinter dem Bot”

L2 • Anwendung

~ 20 min

Lernvideo: Change Management mit ADKAR — Veränderung als Lernreise

Musterlösung

1. Rollenwandel: Die Tätigkeit verschiebt sich von *repetitiver Eingabe* (Daten erfassen, Standardfälle abarbeiten) zu *Steuerung* (Monitoring der Bot-Performance, Ausnahmen bewerten, fachliche Eskalation). Konkret: Was früher 80 % der Zeit “Tippen” war, wird zu 60 % “Prüfen / Entscheiden / Eskalieren”. Neue Skills: Pattern-Erkennung in Logs, kommunikative Stärke (Lieferant ansprechen), grundlegendes Verständnis von Bot-Status und Exception-Codes.

2. Kommunikations-Botschaft (zwei Sätze): “Der *InvoiceBot* übernimmt die Standardfälle, damit Sie mehr Zeit für die Ausnahmen, Lieferantenbeziehungen und Verbesserungen haben. Ihre Rolle wandelt sich von *Erfasser* zu *Entscheider* – mit Training und Begleitung, und wir kommunizieren transparent, wenn sich an Stellenanzahl etwas ändert.”

3. Trainingspfad (drei Stufen):

Stufe	Inhalte (2)	Wirksamkeitsnachweis
Operator	Bot-Status lesen; Standard-Exception auflösen	Auflösung von 3 Standard-Exceptions selbstständig in einer Woche
Owner	Playbook-Pflege; Eskalationsentscheidung treffen	Eine eigenhändig dokumentierte Playbook-Änderung pro Quartal
Champion	Verbesserungsvorschläge; Change-Multiplikator	Eine umgesetzte Verbesserung pro Halbjahr; Mentor für 2 Operator

4. Umgang mit aktivem Widerstand (“Ich werde diesen Bot nicht trainieren”):

- **Zuhören:** Vier-Augen-Gespräch, offene Frage: “Was lässt Sie das so sehen?” – Interessen / Ängste / Verlustsorgen werden konkret. *Zeit: 20 min, nicht eilig.*
- **Reframe:** “Sie kennen den Prozess am besten – ohne Sie wird der Bot Schrott. Wir brauchen Ihre Erfahrung, um die Ausnahmen zu modellieren.” Verantwortung sichtbar machen, nicht moralisch.
- **Klare Konsequenz:** “Ohne Ihren Input geht der Bot trotzdem live – aber schlechter, und Sie tragen die Folgen später mit. Sie haben bis Datum X Zeit, sich zu beteiligen; danach entscheide ich, wer das Team-Wissen liefert.”

5. Drei Frühwarnsignale “Change-Programm scheitert”:

- Krankenstand im Bereich steigt > 30 % über Baseline.
- Anzahl der Vorschläge für Bot-Verbesserungen sinkt gegen null (Disengagement).
- Exceptions werden bewusst übereskaliert (“Operator-Streik” im Stillen).

Aufgabe 8 – Fallstudie “PharmaDistrib”

L2 • Anwendung

~ 40 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Minimum Viable Governance:

- Lifecycle (9 Phasen) verbindlich; pro Bot *Phase-Sign-off* im Ticket.
- RACI über 6 Rollen (Process Owner, Bot Owner, Developer, QA, Security, Operations).
- Release-Gates *risikobasiert*: Low-Risk = 1 Gate (QA + Standards), Medium-Risk = 2 Gates (+ Process Owner), High-Risk = 3 Gates (+ Security Owner). GxP-relevante Bots sind per Definition *High-Risk*.

2. Audit Trail Standard (GxP-tauglich):

- Felder wie in Aufgabe 5 + zusätzlich GxPRelevant (Bool), ChangeReason, SignedOffBy.
- Logs zentral, append-only, role-based Access (Bot Owner, QA, Audit). Operations darf *lesen*, nicht *löschen*.
- Aufbewahrung 5 Jahre (Pharma-Standard), Export als signiertes Archiv für Auditor.
- Integritätsprüfung wöchentlich (Hash-Vergleich).

3. Exception Governance:

Exception	Owner	Reaktion	SLA	Eskalation
MissingBatchNumberSupply Chain		Queue, Rückfrage Werk	8 h	SC-Lead nach 24 h
ERPDnwn	IT-Ops	Retry 3x; Ticket; Queue parken	2 h	Plattform nach 2 h
ApprovalRequired	Bot Owner	Vier-Augen-Task Genehmiger	an 24 h	PO + Bereichsleitung
DuplicateInvoice	Finance	Stop; Prüfung manuell	8 h	PO nach 24 h
PortalUIChanged	Bot Own.+Dev	Bot pausieren; Selektor-Update	24 h	QA + Sec nach 48 h

KPIs: *Exception Rate* $\leq 12\%$, *MTTR* $< 4\text{ h}$; bei Überschreitung Eskalation an Steuerkreis.

4. Security-by-Design Guardrails:

- Bot-Accounts getrennt von Personal-Accounts; `srv_rpa_*`.
- Secrets im Vault, Rotation quartalsweise; bei Audit-Befund sofort.
- SoD strikt: *Anlegen* + *Freigeben* nie im selben Account.
- Logging append-only, PII maskiert; Zugriff auf Logs role-based, Vier-Augen für PII-Logs.

5. Change-Paket:

- *Kernbotschaft*: “Bots übernehmen Routine, damit Sie Compliance und Qualität schärfen können.”

- *Rollenwandel*: Operator → Owner → Champion.
- *Trainingsplan*: 3-stufig; verpflichtende Module zu Audit-Trail und Exception-Playbooks.
- *Champions* je Bereich (mindestens 2 pro Bot) – Multiplikator und Feedbackkanal.

6. Prioritätenempfehlung (4 Wochen):

- *Start*: (a) Audit-Trail-Standard + zentrales Logging, (b) Governance-Minimum (RACI + Gates), (c) drei Exception-Playbooks für Top-Bots.
- *Verschoben*: Vollständige Vendor-Audits und automatisierte Code-Quality-Checks – sinnvoll, aber nicht in 4 Wochen umsetzbar; Auditor akzeptiert Roadmap-Commitment.

Begründung: Vor dem Audit-Sampling zählt *Nachweisbarkeit* mehr als Vollständigkeit – ein sauberer Audit Trail + gelebte Governance schlägt einen unvollständigen, aber technisch ausgefeilten Stack.

Niveau L3 – Management & Entscheidungsarchitektur

Aufgabe 9 – Risk Appetite & Bot-Klassifikation

L3 • Management

~ 35 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Bot-Klassifikation in drei Stufen:

Kriterium	Low	Medium	High
Transaktionswert	< 1.000 €/Vorgang	1.000 – 50.000 €	> 50.000 €
Datensensitivität	öffentlich / intern	vertraulich (PII light)	streng vertraulich (PII / Gesundheit)
Regulator. Relevanz	keine	GoBD / DSGVO Standard	GxP / KRITIS / Major Risk
Reversibilität	sofort rückgängig	in < 24 h korrigierbar	schwer reversibel (Buchung, Zahlung, Personal)

2. Freigabestufen je Klasse:

- *Low*: 1 Gate (QA). Kein Human-in-the-Loop nötig.
- *Medium*: 2 Gates (QA + Process Owner). Human-in-the-Loop bei Schwellen-Überschreitung.
- *High*: 3 Gates (QA + Process Owner + Security). Pflicht: Human-in-the-Loop für jede freigaberelevante Entscheidung; quartalsweiser Sicherheitsreview.

3. Drei klassenübergreifende SoD-Regeln:

- *Anlegen + Freigeben* im selben Account ist verboten.
- *Änderung Bankverbindung + Auslösen Zahlung* sind getrennt.
- *Login-Recht-Vergabe + Audit-Log-Zugriff* liegen nicht beim selben Bot.

Ausnahmen sind nur für *Low-Risk-Bots* mit Read-only-Operationen denkbar; jede Ausnahme braucht schriftliche Vorstands freigabe und endet automatisch nach 6 Monaten.

4. Logging & Retention Standard:

- *Low*: 1 Jahr Aufbewahrung; Standard-Logfelder.
- *Medium*: 3 Jahre; zusätzlich ChangeReason.
- *High*: 7 Jahre; append-only, Hash-Integritätsprüfung wöchentlich, Vier-Augen für Zugriff auf PII-Logs.

5. Zwei Entscheidungen unter Unsicherheit:

- *Fast Track für Low-Risk-Bots erlaubt* – Restrisiko: ein Low-Bot wird fälschlich als Medium klassifiziert. *Frühwarnsignal*: Exception Rate > 15 % oder Audit-Finding zu Logging-Integrität → Fast Track sofort ausgesetzt, alle Low-Bots werden in 14 Tagen reklassifiziert.
- *Human-in-the-Loop nur für High-Risk* – Restrisiko: Medium-Bot baut Schaden auf, der hätte

te gefangen werden können. *Frühwarnsignal*: mehr als ein Incident pro Quartal in Medium-Klasse mit Schadenswert $> 10 \text{ k €}$ → HITL-Pflicht auf Medium erweitern.

6. Vorstandsvorlage (Kernsatz): “Wir führen ein dreistufiges Risk-Appetite-Modell für RPA ein, das schnelle Skalierung bei *Low*-Bots ermöglicht, *Medium*-Bots strukturiert freigibt und *High*-Bots ausnahmslos durch SoD, HITL und 7-Jahres-Audit-Trail absichert; die Klassifikation bindet Aufwand an Risiko und macht Verantwortlichkeit messbar – mit klaren Stoppsignalen, falls die Wirklichkeit von der Klassifikation abweicht.”

Aufgabe 10 – CoE vs. Federation

L3 • Management

~ 30 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

1. Drei Modelle im Vergleich:

Kriterium	CoE-zentral	Föderiert (mit Standards)	Hub-and-Spoke
Skalierungsgeschwindigkeit	langsam (Engpass am CoE)	schnell (jeder baut)	mittel
Qualitätskonsistenz	hoch (alle gleichen Standards)	niedrig (Standards meist papiern)	hoch, wenn Hub stark
Akzeptanz Fachbereich	gering (“die da oben”)	hoch (“mein Bot”)	mittel-hoch
Engpass-Risiko	sehr hoch (CoE-Bottleneck)	gering, dafür Wildwuchs	hoch im Hub bei Reviews
Audit-Tauglichkeit	sehr hoch	gering (Schatten-Bots)	hoch, wenn Hub Sign-off macht

2. Empfehlung für 60 Bots, 8 Bereiche, mittlere Reife: *Hub-and-Spoke (Hybrid)*. Begründung: Bei dieser Größenordnung scheitert reines CoE am Durchsatz, reine Föderation an Qualität. Der *Hub* (zentrales BPM/Security-Team) liefert Standards, Templates, Audit-Pfad und freigibt High-Risk-Bots; die *Spokes* (Bereichs-Developer) bauen autonom, aber innerhalb von Leitplanken.

3. Engpass-Diagnose und Hebel:

- *Engpass*: Security-Review für jeden Bot.
- *Hebel 1*: Automatisierte Code-Checks (Static Analysis) als *Voraussetzung* für Security-Review – fängt 60 % der Befunde maschinell.
- *Hebel 2*: Templates pro Bot-Klasse (z. B. “Read-only-Bot” kommt ohne Vault-Review aus). Self-Service mit harten Guardrails.
- *Hebel 3*: Reviewer-Pool aus 5 zertifizierten Bereichs-Devs (Schulung durch Hub); entlastet das Security-Team.
- *Hebel 4*: Risk-Based Routing – Low-Bots umgehen Security-Review komplett, Medium kriegt Sampling, High immer voll.

4. Drei Frühwarnsignale “Modell stimmt nicht mehr”:

- Anteil “Shadow Bots” (nicht im zentralen Repository) > 15 %.
- Time-to-Production > 8 Wochen für Standard-Bots.
- Audit-Findings zu Logging-/SoD-Bruch > 3 pro Quartal.

5. Faustregel: Ein Operating Model kippt, wenn entweder *Schatten-Bots* (Föderation außer Kontrolle) oder *Time-to-Production* (CoE-Engpass) den Hauptzweck zerstören – spätestens dann braucht es einen bewussten Schwenk, nicht eine weitere Eskalationsrunde.

Aufgabe 11 – Transferprojekt – Enterprise RPA Operating Model

L3 • Management

~ 50 min

Lernvideo: Governance, Risk und Compliance — GRC als Steuerungsrahmen für RPA

Musterlösung

Musterlösung als Entscheidungsarchitektur – andere Konfigurationen sind möglich, solange sie als Architektur (nicht als Liste) gedacht sind.

1. Risk Appetite & Guardrails: Drei-Klassen-Modell (Low/Medium/High) nach Wert, Sensitivität, Regulatorik, Reversibilität. SoD-Regeln (Anlegen+Freigeben getrennt, Bankdaten+Zahlung getrennt). Logging/Retention 1 / 3 / 7 Jahre. Human-in-the-Loop verpflichtend für High.

2. Operating Model: *Hub-and-Spoke*. Hub (zentrales BPM + Security) gibt Standards, Templates, High-Risk-Sign-off; Spokes (Bereichs-Developer) bauen autonom Low/Medium. Eskalation: Spoke-Lead → Hub → CRO → Vorstand.

3. Quality & Release Management:

- *Teststrategie:* Unit + Regression + Recovery; verpflichtende Negative-Tests (was, wenn ERP weg ist?).
- *UAT:* mit echten Fachbereichsdaten in der Test-Umgebung; Sign-off Process Owner.
- *Change-Prozess:* Standard/Normal/Emergency – Emergency mit Post-Mortem Pflicht.
- *Versionierung:* SemVer; Rollback-Plan vor Go-Live.
- *Monitoring-Katalog:* Health, Queue-Tiefe, Erfolgsquote, Exception Rate, MTTR, UI-Drift-Warnung.

4. Exception Governance: Codes zentral, Playbooks pro Top-20-Exception, KPIs (Exception Rate $\leq 12\%$, MTTR < 4 h, Rework $< 5\%$). Quartalsweise Root-Cause-Reviews; daraus eigene Backlog-Tickets im Improve.

5. Security-by-Design Blueprint: Bot-Accounts getrennt; Vault (Rotation quartalsweise); Logging append-only mit Hash-Prüfung; PII maskiert; Portal-Selektoren versioniert; Drittsysteme über Service-Layer (keine direkten UI-Zugriffe wo möglich).

6. Change & Enablement:

- *Stakeholder-Plan:* Bereichsleitung (Sponsor), Operator (Owner), QA, Security, Betriebsrat.
- *Trainingsrollen:* Operator (4 h) → Owner (16 h) → Champion (40 h + Mentoring).
- *Kommunikationsnarrativ:* “Bots nehmen Aufgaben, nicht Würde” – aber mit ehrlichem Hinweis auf mögliche Stellenstrukturen.
- *Erfolgsmessung:* Akzeptanz-Survey, Skill-Shift (% Operator → Owner), Bot-Vorschläge aus dem Fachbereich.

7. Zwei Entscheidungen unter Unsicherheit:

1. *CoE vs. Föderation:* Hub-and-Spoke gewählt. *Annahme:* Standards + Templates + Sampling halten Qualität; Föderation skaliert. *Verworfen Alternative:* reines CoE – fängt Backlog von > 30 Bots nicht ab. *Frühwarnsignal:* Shadow-Bot-Rate $> 15\%$ oder Incident-Rate je Bot $> 2/\text{Quartal}$ → Hub-Kontrolle verschärfen (z. B. Mandatory Review für alle Medium-Bots).

2. *Fast Track Grenze:* Low-Risk-Bots dürfen direkt nach Gate 1 in Prod. *Annahme:* Read-only + niedrige Schwellen fängt 90 % des Restrisikos. *Verworfen Alternative:* Fast Track für alle Klassen (zu riskant). *Frühwarnsignal:* Exception Rate eines Fast-Track-Bots > 15 % oder Audit-Finding zu Logging-Integrität → Fast Track wird für 90 Tage ausgesetzt.

8. Anschluss an Strategie (drei Argumente):

1. *Compliance-Risiko:* Auditfähige Trails und gelebte SoD verhindern Bußgelder und Reputationsschäden – ein Audit-Finding kostet typischerweise mehr als ein Jahr CoE-Budget.
2. *Skalierbarkeit:* Hub-and-Spoke macht Wachstum auf 200+ Bots möglich, ohne dass Security oder QA zum Bremsklotz werden.
3. *Time-to-Value:* Risk-Based Gates verkürzen die durchschnittliche Time-to-Production um 40 % gegenüber zentralisiertem CoE und liefern messbar früher ROI.

Abschluss

Die Musterlösungen sind eine Diskussionsbasis. Wenn Ihre eigene Lösung anders ist, fragen Sie: *Habe ich andere Annahmen – oder eine andere Risikoabwägung?* Beides ist legitim, solange die Logik nachvollziehbar bleibt und Frühwarnsignale benannt sind.

Nächster Schritt

Bringen Sie Ihre Lösungen in die Coaching-Sitzung. Drei Leitfragen: Welche Annahmen liegen Ihren Klassifikationen zugrunde? Wo haben Sie bewusst Restrisiko akzeptiert – und welches Frühwarnsignal würde Sie umsteuern lassen? Wie sichern Sie, dass Governance nicht zur Bürokratie wird, sondern Skalierung ermöglicht?